

Decentra — Feature Test Plan

AI-assisted Decision Intelligence Platform · 2026-09-09 · API v1.0.0 · Env: staging mirror of production (Postgres) · Seed: python seed_demo.py (demo@decentra.ai / demo1234)

How to use: execute each case in order (later sections assume seeded demo data). Mark **Result** Pass/Fail, log defects as BUG-### with the request_id. Entry criteria: /health ok + seeded demo login works. Exit criteria: 100% cases executed, 0 open critical/high defects, pytest + typecheck green.

Automated coverage already guarding this plan: tests/test_core.py (decision lifecycle + provenance + evidence), test_elimination.py, test_robustness.py (cookies, rotation, rate limits, envelopes, upload caps, secret guard), test_extension_flow.py (extension payload end-to-end), test_health.py; web vitest (16). Run: pytest tests/ -q · npm run typecheck · npm run test.

A. Authentication & session

POST /auth/register · /auth/login · /auth/refresh · /auth/logout · GET /auth/me

ID	Test case	Steps	Expected result	Result
A1	Register new account	1. POST /auth/register {email, password≥8, full_name}. 2. Record tokens + Set-Cookie.	200, access+refresh tokens returned, refresh_token cookie is HttpOnly + SameSite=Lax.	■ Pass ■ Fail
A2	Reject weak/duplicate registration	1. Register with 3-char password. 2. Register same email twice.	422 envelope {detail:str, code, request_id}; then 400 Email already registered.	■ Pass ■ Fail
A3	Login + silent refresh rotation	1. Login → use access token on /auth/me. 2. Refresh with the refresh token twice in a row.	Login 200 + cookie set. 1st refresh 200 (token rotated). 2nd replay inside grace 200; replay after grace → 401 Session compromised + family revoked.	■ Pass ■ Fail
A4	Logout kills the session family	1. Login. 2. POST /auth/logout. 3. Replay old refresh token (body).	logout 200 + cookie cleared. Replay → 401. Ledger row shows revoked_at set.	■ Pass ■ Fail
A5	Expired vs invalid token messages	1. Call /auth/me with garbage token. 2. With an expired access token.	401 Invalid token; 401 Token expired (client refreshes instead of logging out).	■ Pass ■ Fail
A6	Auth rate limits hold	1. 12 rapid logins (valid creds). 2. 11 rapid registrations.	11th login → 429; 11th registration in an hour → 429 with Retry-After semantics.	■ Pass ■ Fail

B. Organizations & members

POST/GET /organizations · GET /organizations/{id}/members

ID	Test case	Steps	Expected result	Result
B1	Create + list organizations	1. POST /organizations {name}. 2. GET /organizations.	Org created (unique slug auto-suffixed on clash); creator is ADMIN; list contains it.	■ Pass ■ Fail
B2	Membership enforced	1. Second user requests first user's org members + datasets.	403 Not a member / Not authorized for organization on every route.	■ Pass ■ Fail
B3	Member listing	GET /organizations/{id}/members as member.	200 with [{user_id, email, role}] for each member.	■ Pass ■ Fail

C. Dataset upload & management

POST /datasets/upload · GET /datasets[/all] · GET /datasets/{id} · DELETE

ID	Test case	Steps	Expected result	Result
C1	Upload sales_demo.csv	1. Upload samples/sales_demo.csv with org_id. 2. GET dataset.	200, row_count=288, column_count>0, quality.score=98.9. Detail shows artifact=parquet — never a server storage_path.	■ Pass ■ Fail
C2	Reject bad files	1. Upload .exe. 2. Upload empty CSV. 3. Upload >MAX_UPLOAD_MB (raw 300 MB claim).	400 unsupported/empty with message; 413 Request body too large before RAM is touched.	■ Pass ■ Fail
C3	Row cap + encoding fallback	1. Upload >200k-row CSV. 2. Upload latin-1 CSV.	200k+ rejected with message; latin-1 parses via fallback, no 500.	■ Pass ■ Fail
C4	List isolation + delete	1. List by org_id as member vs outsider. 2. DELETE dataset, re-GET.	Member sees rows; outsider 403. After delete, GET → 404.	■ Pass ■ Fail

D. Data quality

GET /datasets/{id}/quality

ID	Test case	Steps	Expected result	Result
D1	Stored quality report	GET quality for seeded dataset.	score/completeness/validity/uniqueness/consistency + details; score = 0.4·C+0.25·V+0.2·U+0.15·C.	■ Pass ■ Fail
D2	On-the-fly compute + missing artifact	1. Quality for dataset whose report row was deleted. 2. Point storage at a deleted file.	Recomputed live. Missing file → 404 Dataset artifact not found (never a traceback).	■ Pass ■ Fail

E. KPIs & analytics overview

GET /kpis · GET /analytics/overview

ID	Test case	Steps	Expected result	Result
E1	KPI candidates	GET kpis for sales dataset.	Non-empty list; numeric columns carry mean/median/min/max; no NaN leaks (null instead).	■ Pass ■ Fail
E2	Analytics overview	GET analytics/overview.	describe + trends + segmentation + correlation present; datetime column drives trends; 200k-row set responds <10 s.	■ Pass ■ Fail

F. Anomaly detection

GET /datasets/{id}/anomalies · web /anomalies

ID	Test case	Steps	Expected result	Result
F1	Known spike found	GET anomalies on sales data (West spike Mar-2024 seeded in generator).	200, count≥1, each item has column/value/score/explanation (z-score or IQR method named).	■ Pass ■ Fail
F2	Web anomalies tab	Open dataset → Anomalies tab.	Table renders, method badge shown, clicking a row highlights the chart point.	■ Pass ■ Fail

G. Forecasting

GET /datasets/{id}/predictions · web /predictions

ID	Test case	Steps	Expected result	Result
G1	Forecast with horizon	GET predictions?horizon=6 on sales data.	Forecast points = horizon with lower/upper bands; insufficient series → {forecast:null, message} (not 500).	■ Pass ■ Fail
G2	Invalid horizon	GET predictions?horizon=-3.	422 validation envelope, never an exception trace.	■ Pass ■ Fail

H. Insights & recommendations

GET /insights · GET /recommendations · web /insights

ID	Test case	Steps	Expected result	Result
H1	Auto insights	GET insights.	Non-empty insights each with evidence refs; top-5 anomalies attached.	■ Pass ■ Fail
H2	Ranked recommendations	GET recommendations.	List ordered by priority with rationale + linked insight/anomaly ids.	■ Pass ■ Fail
H3	Web insights page	Open /insights for the dataset.	Cards render, evidence links jump to the underlying computation.	■ Pass ■ Fail

I. Dataset assistant (evidence Q&A;) + conversations

POST /datasets/{id}/assistant/query · GET /conversations · GET /conversations/{id}/messages

ID	Test case	Steps	Expected result	Result
I1	Grounded answer	Ask 'Why did revenue decline in North in H2 2024?'.	200 with {answer, evidence[], confidence, conversation_id}; every numeric claim traceable to evidence_list; no raw rows leak to the LLM path.	■ Pass ■ Fail
I2	Missing question rejected	POST query with {}.	400 question required.	■ Pass ■ Fail
I3	Conversation memory	1. Ask 2 questions (reuse conversation_id). 2. List conversations + messages.	Same conversation_id continues; history lists both turns in order with roles.	■ Pass ■ Fail
I4	Cross-user isolation	Second user GETs first user's conversation messages.	404 Conversation not found (no cross-user read).	■ Pass ■ Fail
I5	Cached repeat is instant	Ask the same question twice (dataset + meetings assistant).	2nd answer carries cached:true + ■ instant badge, latency_ms=0, identical text. New upload/decision re-asks fresh (fingerprint invalidation).	■ Pass ■ Fail

J. Meetings

POST/GET /meetings · GET /meetings/{id} · web /meetings

ID	Test case	Steps	Expected result	Result
J1	Create + list + filter	1. POST /meetings {title} for org. 2. GET /meetings, with ?q= and ?status=.	Meeting created status=draft, creator auto-participant. Filters narrow correctly.	■ Pass ■ Fail
J2	Org isolation	Outsider GETs meeting / list with victim org_id.	403 on all paths; other org's meetings never listed.	■ Pass ■ Fail
J3	Web meetings page	Open /meetings → open a meeting.	List, status chips, detail with tabs (transcript/intelligence/verdict).	■ Pass ■ Fail

K. Recording upload & transcription

POST /meetings/{id}/recording

ID	Test case	Steps	Expected result	Result
K1	JSON transcript ingest	Upload transcript.json {segments:[{speaker,start,end,text}]}	200 {storage_key, status:processing}; .json/.txt parsed to segments.	■ Pass ■ Fail
K2	Audio validation	1. Upload .exe. 2. Empty file. 3. >MAX_RECORDING_MB stream.	400 unsupported/empty; oversized → 413 mid-stream (worker never OOMs).	■ Pass ■ Fail
K3	Honest no-source failure	Process a meeting with audio only and no OPENAI_API_KEY.	Job fails with 'No transcript available...' — never fabricated dialogue.	■ Pass ■ Fail

L. Processing pipeline & evidence views

POST /meetings/{id}/process · GET /status · /transcript · /intelligence

ID	Test case	Steps	Expected result	Result
L1	Full pipeline	1. Upload JSON transcript with decision/action/question cues. 2. POST process. 3. Poll status.	Job queued→running→done; transcript segments persisted with ms timings; intelligence rows created.	■ Pass ■ Fail
L2	Transcript fidelity	GET transcript after pipeline.	Segments in position order, speaker labels + start/end ms + confidence intact.	■ Pass ■ Fail
L3	Intelligence grounded	GET intelligence.	Decisions carry transcript_segment_ids pointing at real segments; actions have owners/statuses.	■ Pass ■ Fail
L4	Idempotent reprocess	POST process twice while running.	Second call returns {status:processing, job_id} — no duplicate pipeline.	■ Pass ■ Fail

M. Decision lifecycle + review queue

PATCH /decisions/{id} · GET /review_queue · POST /review/{id}/decision

ID	Test case	Steps	Expected result	Result
M1	Legal transitions	PATCH DETECTED→CONFIRMED, CONFIRMED→REVISED.	200 each; every mutation writes an audit row (incl. auto-supersede side effects).	■ Pass ■ Fail
M2	Illegal jump rejected	PATCH DETECTED→COMPLETED (or any off-graph edge).	400 Invalid transition; state unchanged.	■ Pass ■ Fail
M3	Review accept/reject/edit	1. Queue item → accept. 2. Reject. 3. Edit title.	Status moves identically to PATCH paths; provenance rows complete (regression: test_core).	■ Pass ■ Fail
M4	Foreign evidence rejected	PATCH decision with segment ids from another meeting.	400; no cross-meeting evidence links persist.	■ Pass ■ Fail

N. Action items

GET /actions · PATCH /actions/{id}

ID	Test case	Steps	Expected result	Result
N1	Lifecycle	PATCH NOT_STARTED→IN_PROGRESS→COMPLETED; try COMPLETED→NOT_STARTED.	Forward moves 200; backward jump 400 per transition table.	■ Pass ■ Fail
N2	Owner + deadline	Action with owner_name + 'Friday' deadline → check parsed deadline + notification.	deadline parsed, owner notification queued once (no dupes within an hour).	■ Pass ■ Fail

O. Questions & risks

part of intelligence payload

ID	Test case	Steps	Expected result	Result
01	Question capture	Transcript containing 'Which provider should we use?' → intelligence.	OPEN question row with evidence segment ids.	■ Pass ■ Fail
02	Risk capture	Transcript containing 'may not handle the traffic' → intelligence.	Risk row with severity + evidence; visible on verdict page.	■ Pass ■ Fail

P. Decision DNA · research · challenge · recommendation

GET /decisions/{id}/dna · /research · /challenge · /recommendation

ID	Test case	Steps	Expected result	Result
P1	Decision DNA	GET dna for a CONFIRMED decision.	200 with lineage (segments → decision → confirmations/supersedes).	■ Pass ■ Fail
P2	Research without key	GET research with no TAVILY_API_KEY.	status=unavailable + guidance; zero fabricated sources/links.	■ Pass ■ Fail
P3	Challenge + recommendation	GET challenge, GET recommendation.	Challenge lists concerns/questions; recommendation gives next step with rationale. Both 200.	■ Pass ■ Fail

Q. Understanding · brief · elimination · ROI

GET /understanding · /brief · /elimination · GET /roi/meetings

ID	Test case	Steps	Expected result	Result
Q1	Meeting understanding	GET understanding after pipeline.	Summary + participants analysis + DecisionDNA present.	■ Pass ■ Fail
Q2	Brief + elimination	GET brief; GET elimination.	Brief renders executive summary; elimination flags redundant meetings with reasons.	■ Pass ■ Fail
Q3	ROI	GET /roi/meetings.	Per-meeting time-saved/cost math; empty org → zeros, not 500.	■ Pass ■ Fail

R. Comments · notifications · activity · audit · report

POST/DELETE comments · notifications · /activity · /audit · /report

ID	Test case	Steps	Expected result	Result
R1	Comment round-trip	1. POST comment. 2. GET comments. 3. DELETE comment.	Visible after post; gone after delete; outsider gets 403/404.	■ Pass ■ Fail
R2	Notifications	Trigger an action assignment → GET notifications → POST read.	Unread appears once; read marks it; counter drops.	■ Pass ■ Fail
R3	Activity + audit	GET activity; GET audit after decision mutations.	Timeline ordered; every mutation has an audit row with actor + timestamp.	■ Pass ■ Fail
R4	Report export	GET /meetings/{id}/report.	200 with decisions/actions/questions/risks compiled; no internal paths inside.	■ Pass ■ Fail

S. Search · memory · ledger · health score

GET /search · /memory · /ledger · /health/score

ID	Test case	Steps	Expected result	Result
S1	Search	GET /search?q=postgres (member) vs outsider.	Member gets ranked hits across meetings/decisions; outsider sees nothing (403/empty).	■ Pass ■ Fail
S2	Memory + ledger	GET /memory; GET /ledger.	Memory returns org facts; ledger lists evidence-anchored entries.	■ Pass ■ Fail
S3	Meeting health score	GET /health/score?meeting_id=.	0–100 score with components; missing meeting → 404.	■ Pass ■ Fail

T. Web application routes (27 pages)

apps/web/app — each: loads 200, key interaction works

ID	Test case	Steps	Expected result	Result
T1	Public: / · /login · /register	1. Landing renders + manifesto scrub fills on scroll. 2. Login demo creds → /overview. 3. Register new user → workspace.	No console errors; ?next= return path honored after login; demo box visible.	■ Pass ■ Fail
T2	Workspace: /overview · /projects · /datasets · /datasets/[id]	1. Overview stats load. 2. Upload CSV. 3. Dataset detail tabs (quality/KPIs/anomalies/predictions/evidence).	Upload progress + quality score appear; 413 message on oversized file; charts render.	■ Pass ■ Fail
T3	Analysis: /analytics · /anomalies · /predictions · /insights · /recommendations · /assistant	Ask a question in /assistant; open each tab.	Answers show citations + View Evidence; silent refresh keeps session alive across reload.	■ Pass ■ Fail
T4	Meetings: /meetings · /meetings/[id] · /verdict · /review · /decisions · /actions · /questions · /timeline	Walk a processed meeting end-to-end; confirm/reject a review item.	Verdict shows decisions/actions/questions/risks with evidence links; review updates status + audit.	■ Pass ■ Fail
T5	Knowledge: /intelligence · /knowledge-graph · /roi · /reports(?) · /settings · /onboarding	1. Toggle settings. 2. Complete onboarding as new user. 3. ROI + knowledge-graph render.	Settings persist; onboarding creates org; graphs render without 500 on empty data.	■ Pass ■ Fail
T6	Failure UX	1. Visit /nope. 2. Block API (offline) and load /overview. 3. Expire session (logout API-side) then click around.	Branded 404; offline shows error state (not blank); expired session → silent refresh or clean ?next= login redirect.	■ Pass ■ Fail
T7	Streaming answers	Ask in /assistant and watch; ask again (cached); abort by asking a second question mid-stream.	Evidence line appears first, tokens flow into the bubble, full AnswerBlock replaces it on done; repeat shows ■ instant; superseded stream never overwrites the newer turn.	■ Pass ■ Fail

U. Chrome extension (Meet capture)

apps/extension — install: chrome://extensions → Load unpacked

ID	Test case	Steps	Expected result	Result
U1	Install + sign in	1. Load unpacked. 2. Set API/Web URLs (allow host). 3. Sign in as demo user. 4. Load orgs.	Popup shows org list; invalid creds → 'Invalid email or password'.	■ Pass ■ Fail
U2	Live capture	1. Join Meet with CC on. 2. Start capture. 3. Speak 30 s.	Counter climbs (lines/words/elapsed). Stuck at 0 with CC on → update SELECTORS (see README).	■ Pass ■ Fail
U3	Stop → Decentra link	Stop & process → follow Open in Decentra link.	Meeting page shows transcript + intelligence from captions; decisions carry evidence.	■ Pass ■ Fail
U4	No-captions guard	Start capture with CC off, speak, stop.	Clean error 'No captions captured...' — no empty meeting processing.	■ Pass ■ Fail

V. Robustness & security (non-functional)

main.py · settings · Docker · compose

ID	Test case	Steps	Expected result	Result
V1	Production secret guard	APP_ENV=production with default SECRET_KEY → boot.	Refuses to start with actionable error. Short key (<32) refused in any env.	■ Pass ■ Fail
V2	Security headers + envelope	GET any route → inspect headers + force a 404/422.	nosniff/DENY/Referrer-Policy/Permissions-Policy present; errors are {detail:str, code, request_id}.	■ Pass ■ Fail
V3	Deep health gating	1. GET /health with DB down. 2. docker healthchecks.	503 {status:degraded, checks} — orchestrator stops routing; /readyz false.	■ Pass ■ Fail
V4	Upload DoS resistance	POST 300 MB Content-Length claim, no body.	413 before any body bytes are read (verified live).	■ Pass ■ Fail
V5	Cookie + rotation invariants	Automated: tests test_refresh_reuse_*, test_logout_kills_*.	pytest green: single-use rotation, grace concurrency, theft burns family, logout kills all.	■ Pass ■ Fail
V6	Images run least-privilege	docker inspect api/web images.	Non-root user; HEALTHCHECK present; api has no alembic `   true` boot.	■ Pass ■ Fail
V7	Realtime load path	1. Same question twice → 2nd instant. 2. Kill Groq key mid-run → ask. 3. `docker compose -f docker-compose.yml -f docker-compose.prod.yml up` → 2 workers share Redis buckets (12 rapid logins still 429s).	Cache hit ~0 ms; LLM failure degrades to templates, never 500s; limits hold across workers (not multiplied).	■ Pass ■ Fail

Sign-off

Tester: _____ Date: _____ Result:

■ Release

■ Release with notes

■ Blocked

 Open defects: _____